SAE 1.01 : SE SENSIBILISER A L'HYGIENE INFORMATIQUE ET A LA CYBERSECURITE

PROJET : CATALOGUE DE VULNÉRABILITÉS



SOMMAIRE

SOMMAIRE **2**
introduction : **3**
Problématique : **4**
1) partie pour Matéo **4**
A) Comprendre les E-mails de Phishing 4
Qu'est-ce qu'un e-mail de phishing ? 4
Comment reconnaître un e-mail de phishing ? 4
Mesures de protection 5
Exemples de phishing 5
Conclusion 6
B)Vulnérabilités des API et Sécurité 6
Qu' est ce qu' un API? 6
Qu'est-ce que la sécurité des API ? 6
Top 10 des vulnérabilités des API en 2023 6
Conclusion 9
2) Partie pour Yann **10**
3) partie pour Imane **16**
a) vulnérabilité de logiciels 16
Introduction : 16
A. Types de vulnérabilités logicielles et exemples d'attaques 17
1. Désérialisation non sécurisée 17
2. Faille de type "Race Condition" (condition de course) 17
3. Exposition de données sensibles (Sensitive Data Exposure) 17
B. Les méthodes employées par les attaquants pour exploiter ces failles 18
C. Conséquences d'une mauvaise gestion des vulnérabilités et mesures de protection avancées 19
b)vulnérabilité liés aux contrôle d'accès 20
Contrôle d'accès physique : 20
Contrôle d'accès logique : 20
Les attaques en contrôle d'accès logique : 20
L'attaque par force brute: 20
L'attaque par force brute simple : 21
la force brute avec dictionnaire : 21
L'attaque hybride : 21
Comment s'en protéger ? 22
conclusion : **28**

introduction :

Le monde numérique étant en constante évolution, il est essentiel de veiller à la sécurité de nos systèmes informatiques. Ce catalogue de vulnérabilités a pour but de sensibiliser aux dangers qui menacent nos données et de fournir des solutions pour y faire face. Nous, étudiants en BUT, pensons qu'il est important de vous faire prendre conscience que chaque partie de la chaîne numérique peut être vulnérable. Ce document met en lumière des problèmes courants et offre des conseils pratiques pour améliorer la sécurité de nos environnements numériques. En adoptant de bonnes habitudes et en apprenant à connaître les risques, nous serons mieux préparés à protéger nos informations et celles de nos futurs employeurs.

Qu'est ce que la vulnérabilité d’un système informatique ?

La vulnérabilité d'un système informatique est une faiblesse qui peut être exploitée par des hackers pour compromettre la sécurité d’un système informatique.

Quelles sont les conséquences d’une vulnérabilité informatique ?

Les conséquences d’une vulnérabilité informatique peuvent inclure la perte de données sensibles, des violations de la confidentialité, des interruptions de service, des pertes financières et une atteinte à la réputation d'une organisation.

Quelles sont les solutions pour éviter cela ?

Les solutions pour éviter cela est de mettre en place plusieurs solutions clés : maintenir les systèmes et logiciels à jour, utiliser des pare-feu et des antivirus, adopter une gestion stricte des mots de passe (notamment avec l’authentification à deux facteurs), et former les utilisateurs à la cybersécurité. Il est également crucial de limiter les accès aux données sensibles, de réaliser des sauvegardes régulières, de chiffrer les données et de tester régulièrement les systèmes via des audits de sécurité..

Problématique :

En quoi notre catalogue sur la vulnérabilité d'un système informatique va vous ouvrir les yeux sur les dangers de l'informatique ?

1) partie pour Matéo

A) Comprendre les E-mails de Phishing

Qu'est-ce qu'un e-mail de phishing ?

Un e-mail de phishing est un message trompeur qui semble provenir d'un expéditeur de confiance, conçu pour inciter le destinataire à fournir des informations personnelles ou à cliquer sur un lien malveillant. Ces attaques exploitent l'usurpation d'identité pour récupérer des données sensibles, souvent financières.

Types courants de phishing :

- **Phishing classique :** Faux formulaires pour obtenir des informations bancaires.
- **Phishing Police :** Menaces de poursuites judiciaires pour inciter à agir.
- **Spear phishing :** Ciblage spécifique d'une entreprise en utilisant des informations connues.

Comment reconnaître un e-mail de phishing ?

Pour identifier un phishing, examinez ces éléments :

Vérification de l'expéditeur : L'expéditeur est-il connu ? Vérifiez l'adresse e-mail pour des anomalies.

Analyse du format : La mise en page est-elle cohérente avec les messages habituels ? Vérifiez la police, les images et la signature.

Évaluation de la demande :

La demande est-elle crédible ? Pouvez-vous la vérifier par un autre moyen ?

Points à retenir : Les e-mails de phishing peuvent sembler très professionnels et usurper des adresses connues.

Mesures de protection

Formation : Sensibiliser régulièrement les employés aux e-mails de phishing.

Filtrage : Utilisez des logiciels pour bloquer les e-mails suspects.

Vérification : Incitez à vérifier les adresses e-mail avant d'interagir.

Prudence avec les liens : Visitez directement les sites sans cliquer sur des liens suspects.

Authentification à deux facteurs (2FA) : Mettez en place 2FA pour les comptes sensibles.

Mises à jour régulières : Assurez-vous que tous les logiciels sont à jour.

Surveillance : Surveillez le trafic réseau pour détecter des attaques.

Renforcement des mots de passe : Encouragez l'utilisation de mots de passe forts et leur changement régulier.

Politiques de sécurité : Établissez des règles sur l'utilisation des e-mails et des appareils personnels.

Exemples de phishing

Arnaque des fausses factures : Emails contenant de fausses factures pour produits de sécurité ou faux fournisseurs.

Faux e-mails de support technique : Créent un sentiment d'urgence pour inciter à cliquer.

Arnaques fiscales : Surtout pendant la saison des impôts, ciblent les employés financiers.

Problème de compte e-mail : Messages urgents sur la suspension de compte (ex. Microsoft).

Arnaque de Google Docs : Notifications de commentaires sur des documents avec des liens malveillants.

Conclusion

La sensibilisation à la cybersécurité et la formation continue sont essentielles pour réduire les risques de phishing. En identifiant les signes de phishing et en appliquant des mesures de protection, les entreprises peuvent mieux se défendre contre cette menace. La vigilance et l'éducation sont cruciales pour garantir la sécurité des informations sensibles.

https://www.altospam.com/actualites/decouvrez-les-exemples-des-principaux-e-mails-de-phishing/
https://www.metacompliance.fr/blog-cybersecurite/phishing-et-ransomware/exemple-mail-phishing-hameconnage

https://www.youtube.com/watch?v=sS3mZVCARZg

B)Vulnérabilités des API et Sécurité

Qu' est ce qu' un API?

Une API (Application Programming Interface) est un ensemble de règles qui permet à des applications de communiquer entre elles, en définissant des méthodes et des formats de données à utiliser. Elle facilite l'intégration de fonctionnalités sans nécessiter une connaissance approfondie du fonctionnement interne des systèmes.

Qu'est-ce que la sécurité des API ?

Les API sont cruciales pour la communication entre applications, mais elles exposent des données sensibles, les rendant vulnérables aux attaques. La sécurité des API vise à atténuer ces failles pour protéger les données.

Top 10 des vulnérabilités des API en 2023

1. Autorisation au niveau de l'objet rompue

Risques : Accès non autorisé à des données sensibles.

Exemple : Accéder à des informations d'autres comptes en modifiant l'ID dans l'URL.

Mesures : Contrôles d'autorisation stricts pour chaque point de terminaison.

2. Authentification interrompue

Risques : Usurpation d'identité et accès non autorisé.

Exemple : Utiliser un jeton compromis pour accéder au compte d'un utilisateur.

Mesures : Protocoles d'authentification sécurisés et rotation régulière des jetons.

3. Autorisation au niveau de la propriété d'un objet brisée

Risques : Manipulation des données par des utilisateurs non autorisés.

Exemple : Modifier un champ dans une requête pour changer des informations d'utilisateur.

Mesures : Validation des autorisations au niveau des propriétés pour chaque requête.

4. Consommation illimitée de ressources

Risques : Déni de service et coûts accrus.

Exemple : Envoyer des requêtes massives pour surcharger le serveur.

Mesures : Limitation de taux et quotas d'utilisation.

5. Autorisation de niveau de fonction interrompue

Risques : Accès non autorisé à des fonctionnalités critiques.

Exemple : Utilisateur normal accédant à des fonctions d'administration.

Mesures : Simplification des politiques de contrôle d'accès.

6. Accès illimité aux flux commerciaux sensibles

Risques : Utilisation abusive des fonctionnalités.

Exemple : Automatisation de l'achat de billets par un bot.

Mesures : Limiter les actions sensibles par des contrôles d'accès.

7. Falsification de requête côté serveur (SSRF)

Risques : Accès à des ressources internes.

Exemple : Manipuler l'API pour accéder à des données internes.

Mesures : Validation des URIs fournies par les utilisateurs.

8. Mauvaise configuration de sécurité

Risques : Exposition de données.

Exemple : Serveur exposé à Internet sans restrictions.

Mesures : Suivre les meilleures pratiques de configuration.

9. Mauvaise gestion des stocks

Risques : Utilisation d'API obsolètes.

Exemple : Points de terminaison de débogage exposés en production.

Mesures : Inventaire à jour des API déployées.

10. Consommation dangereuse d'API

Risques : Faiblesses de sécurité avec les services externes.

Exemple : Service tiers compromis affectant l'API principale.

Mesures : Évaluation de la sécurité des API tierces.

Bug d’API Instagram : 6 millions d’utilisateurs auraient été victimes en 2017 ?

Le bug d’une API d’Instagram a permis à des internautes de récupérer les coordonnées des célébrités, notamment leur numéro de téléphone et adresse e-mail. Cette semaine, le réseau social a corrigé ce problème et a vérifié les profils des « utilisateurs de premier plan ». Selon Ars Technica, cette faille de sécurité a permis d’atteindre un grand nombre d’utilisateurs, 6 millions de comptes pour être plus précis. T

Conclusion

La sécurité des API est essentielle pour protéger les applications modernes. En comprenant et en atténuant ces vulnérabilités, on peut réduire considérablement les risques. La formation continue des développeurs et des équipes de sécurité est cruciale pour maintenir une bonne posture de sécurité.

https://owasp.org/www-project-api-security/

$
https://www.sekurigi.com/2017/10/bug-dapi-instagram-6-millions-dutilisateurs-auraient-ete-victimes/

2) Partie pour Yann

a) Vulnérabilités de chiffrement des données

Qu’est ce que le chiffrement de données ?

Le chiffrement est un moyen de protéger des informations en les transformant en un code secret que personne ne peut lire sans une clé spéciale. C'est comme si on mettait des données dans une boîte fermée à clé. Cela aide à garder nos informations privées et sécurisées, à vérifier si quelqu'un est bien qui il dit être, et à décider qui peut accéder à certaines ressources ou services.

Le chiffrement est très important pour la sécurité sur Internet. Il permet de s'assurer que nos données, comme nos messages ou nos informations personnelles, restent cachées et en sécurité. En utilisant le chiffrement, on empêche les personnes malintentionnées d'accéder à nos informations sans notre autorisation, ce qui rend les échanges en ligne plus sûrs.

Quels types de cryptographie existent-ils ?

Les dispositifs de cryptage sont habituellement configurés par des clés. L'intégrité et/ou la confidentialité de ces clés constituent un facteur prédominant pour assurer la sécurité de ces mécanismes.

En réalité, le chiffrement peut présenter une symétrie ou une asymétrie :

- **Chiffrement symétrique :** Ce type de chiffrement utilise une seule clé pour chiffrer et déchiffrer les données. L’algorithme le plus connu dans cette catégorie est l’AES (Advanced Encryption Standard).
- **Chiffrement asymétrique :** Ce système utilise une paire de clés : une clé publique pour chiffrer les données et une clé privée pour les déchiffrer. RSA (Rivest-Shamir-Adleman) est l'un des algorithmes les plus populaires dans cette catégorie.
- **Chiffrement de hachage :** Utilisé pour créer une représentation fixe (appelée "hachage") d'un ensemble de données, ce type de chiffrement est unidirectionnel et ne peut pas être inversé. Les algorithmes comme SHA-256 (Secure Hash Algorithm) et MD5 (Message Digest Algorithm 5) sont couramment utilisés.

Par exemple, dans un dispositif de signature numérique, une entité détient une clé de signature personnelle, tandis que la clé de vérification peut être diffusée.

La clé publique est utilisée pour convertir un message clair en un message chiffré dans le processus public de cryptage. Parallèlement, le déchiffrement donnera la possibilité d'exprimer clairement la communication via le message encodé et la clé privée.

Quelles sont les exploitations courantes de manque de chiffrement ?

Un chiffrement inadéquat des mots de passe dans une base d'informations :

Lorsque les mots de passe d'une base de données ne sont pas correctement chiffrés, cela peut avoir de graves conséquences. Si un pirate parvient à accéder à cette base, il pourrait facilement lire les mots de passe.

Cela transforme ce qui pourrait être une simple fuite d'informations en une véritable catastrophe, car l'attaquant pourrait alors se connecter à des comptes, notamment ceux des administrateurs. Cela mettrait en danger toute la plateforme, permettant au pirate d'avoir un contrôle important sur celle-ci.

- **Injection SQL**

  L'injection SQL, quant à elle, implique l'insertion de code malveillant dans des requêtes pour accéder à des données sensibles. Cette attaque exploite des vulnérabilités liées à un chiffrement insuffisant des données. Pour se protéger, il est essentiel de renforcer le chiffrement, de valider les entrées et d'utiliser des requêtes préparées.

- **Attaque par force brute**

  L'attaque par force brute est une méthode utilisée par des cybercriminels pour accéder à des comptes ou systèmes en essayant toutes les combinaisons possibles de mots de passe, ce qui est particulièrement efficace lorsque le chiffrement des mots de passe est inadéquat.

  Si les mots de passe sont mal chiffrés, tels que ceux utilisant des algorithmes obsolètes ou de faibles longueurs, un attaquant peut rapidement déchiffrer les mots de passe avec des outils automatisés.

  Exemple Attaque brute de force par dictionnaire : John the Ripper est l'outil le plus répandu pour dérober des mots de passe. Dans notre situation, nous

l'utiliserons en tant que liste de mots-clés associé à un dictionnaire de mots de passe : rockyou.txt.

Une protection efficace contre ce type d'attaque inclut l'utilisation de mots de passe longs et complexes, le chiffrement fort, ainsi que l'authentification multifacteur, qui rendent les tentatives de force brute beaucoup plus difficiles et chronophages.

Sécuriser les mots de passe : L'importance du hachage et des bonnes pratiques

Pour sécuriser le stockage des mots de passe, il est essentiel d'utiliser des **algorithmes de hachage robustes** tels que **Argon2**, **scrypt**, **bcrypt** ou **PBKDF2**, qui résistent aux **attaques par force brute** et par **dictionnaire**.

Pour renforcer la sécurité, les mots de passe doivent être une **chaîne de caractères aléatoire** unique et avec une chaîne partagée, stockée sur le **serveur applicatif**. Cela rend l'accès aux mots de passe compromis très difficile pour un attaquant.

Une **politique de mots de passe solides** est également nécessaire, imposant des exigences de **complexité** et encourageant le changement régulier des mots de passe.

De plus, le stockage des mots de passe en clair ou avec des algorithmes obsolètes peut entraîner des **sanctions judiciaires** en vertu du **RGPD**, ce qui souligne l'importance d'adopter des pratiques de sécurité adéquates pour protéger les données sensibles des utilisateurs.

Les principales méthodes de chiffrement (Tableau) :

Methode de chiffrement	Type	Caractéristiques	Avantages (+)	Inconvénients (-)	Versions
AES **(Advanced Encryption Standard)**	*Symétrique*	Utilise des clés de 128, 192, 256 bits pour chiffrer des blocs de données	Très sécurisé et efficace	Plus complexe à implémenter	AES-128, AES-192, AES-256
RSA **(Rivest-Shamir-Adleman)**	*Symétrique*	Utilise une paire de clés, une publique pour chiffrer et une privée pour déchiffrer	Sécurise les échanges et permet la signature numérique	Plus lent lque le chiffrement symétrique	RSA-1024 RSA-2048 RSA-4096
SHA-256 **(Secure Hash Algorithm)**	*Hachage*	Génère un hachage fixe de 256 bits à partir des données d'entrée	Assure 'intégrité des données et est irréversibles	Ne permet pas de déchiffrer les données originales	SHA-1 SHA-256 SHA-512
SSL/TLS	*Asymétrique*	Protocole qui chiffre les communications sur Internet avec des certificats	Sécurise les échanges de données sur le web	Nécessite une infrastructure de gestion des certificats	SSL 3.0 TLS 1.0 TLS 1.2 TLS 1.3

Se protéger de la vulnérabilités :

Le **chiffrement des données** est vital pour garantir la **sécurité** et la **confidentialité** des informations sensibles. L'utilisation d'algorithmes robustes, comme ceux de **hachage**, ainsi que des pratiques comme le **salage** des mots de passe, renforce la protection contre les **attaques**. Il est également essentiel de se conformer aux réglementations, telles que le **RGPD**, pour éviter des sanctions. En intégrant ces mesures, nous pouvons mieux sécuriser nos données face aux cybermenaces.

Salage : ajoute une chaîne aléatoire à un mot de passe avant de le transformer en code, rendant ainsi plus difficile son piratage.

b) Vulnérabilités de sessions(Détournement de session)

Qu’est-ce que le détournement de session ?

Le détournement de session, également connu sous le nom de "session hijacking," est une attaque où un cybercriminel intercepte une session de communication entre un utilisateur et une application, dans le but de s’introduire dans cette session et d'agir en tant qu’utilisateur légitime. Ce procédé est rendu possible grâce à la capture d’un identifiant de session unique (token de session) associé à l'utilisateur authentifié. En accédant à cette session, l'attaquant peut usurper l'identité de l'utilisateur et accéder aux informations, aux services et aux privilèges qui lui sont associés.

Les attaques de détournement de session représentent une menace sérieuse pour la sécurité des données, compromettant la confidentialité et l'intégrité des informations et services accessibles par l’utilisateur légitime.

Quels types d'attaques de détournement de session existent-ils ?

- **Le contournement de l'authentification multifacteur (MFA)**

  Le contournement de l'authentification multifacteur (MFA) est une technique que les pirates utilisent pour accéder à un compte sans devoir passer par toutes les étapes de sécurité, comme le code envoyé par SMS. Normalement, la MFA ajoute une protection : après avoir entré son mot de passe, on doit entrer un code supplémentaire, prouvant qu’on est bien le propriétaire du compte.

  Mais les attaquants peuvent contourner cela en utilisant une méthode de tromperie, comme le phishing. Par exemple, ils envoient un faux email qui semble venir d’un site officiel, demandant à la personne de se connecter pour une « mise à jour de sécurité ». La personne, sans se méfier, clique sur le lien et se retrouve sur une page qui ressemble à la vraie, mais qui est contrôlée par le pirate.

  Quand elle entre son mot de passe et son code, ces informations passent directement par le pirate, qui peut ensuite les utiliser pour se connecter lui-même sur le vrai site. Comme le pirate a maintenant accès à la connexion déjà validée par le vrai utilisateur, il n’a plus besoin de refaire les étapes de sécurité. Cela lui donne un accès complet au compte, sans que la personne s'en aperçoive.

- **Interception de la session par manipulation de session**

  L’attaquant accède aux identifiants de session par des moyens techniques, comme l'ingénierie sociale ou la manipulation de sessions existantes, afin de modifier ou réutiliser ces identifiants pour accéder aux privilèges associés.

  Applications courantes de détournement de sessions en cas de défaut de sécurité

- **Absence de chiffrement (HTTPS)**

  Sans HTTPS, toutes les informations transmises entre l'utilisateur et le serveur sont envoyées en texte clair, ce qui rend le reniflage de session trivial sur les réseaux non sécurisés. Un attaquant peut intercepter et voler l'ID de session, accédant ainsi aux ressources et informations sans authentification.

- **Défaut de gestion des sessions**

  Lorsque la gestion des sessions n'est pas rigoureuse, par exemple en n'invalidant pas les sessions après la déconnexion ou après un certain temps d’inactivité, l’attaquant peut réutiliser l'ID de session d’une session précédemment active, prolongeant son accès non autorisé à la plateforme.

Méthodes de protection contre le détournement de sessions

- **Chiffrement de bout en bout (HTTPS)**

  Il est essentiel de sécuriser la transmission des données via HTTPS pour empêcher les interceptions de session sur le réseau. HTTPS chiffre toutes les données échangées entre l'utilisateur et le serveur, rendant l'écoute de session beaucoup plus difficile pour les attaquants.

- **Politique de gestion des sessions**

  Mettre en place une politique de gestion des sessions efficace est indispensable pour réduire les risques de détournement. Cette politique peut inclure l'invalidation des sessions après un certain délai d'inactivité, la déconnexion forcée après une certaine durée, et la réinitialisation des identifiants de session après une authentification ou une action critique.

Conclusion

Le détournement de session représente une menace sérieuse pour la sécurité des informations personnelles et professionnelles. En s'emparant d'une session active, les attaquants peuvent contourner les mesures de sécurité habituelles et accéder à

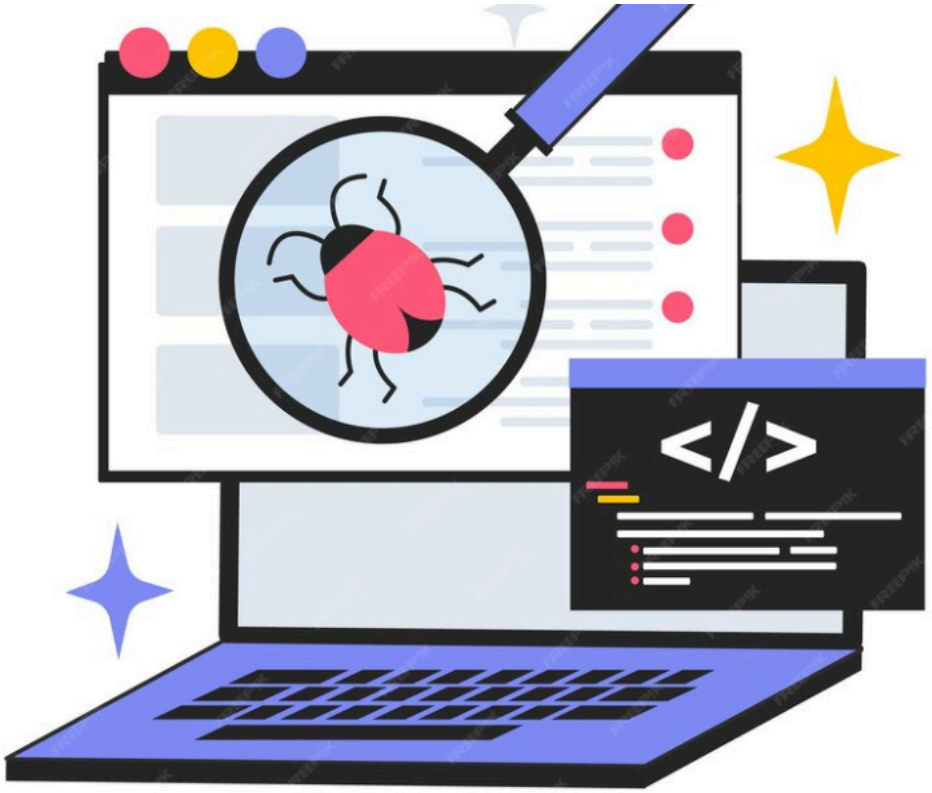
des données sensibles. Bien que des protections comme le chiffrement HTTPS et une bonne gestion des sessions réduisent les risques, la vigilance des utilisateurs et l'application de politiques de sécurité rigoureuses restent essentielles pour contrer ces attaques. Face à des techniques de piratage de plus en plus sophistiquées, renforcer continuellement les pratiques de cybersécurité est crucial pour préserver la confidentialité et l'intégrité des systèmes et des données.

3)partie pour Imane

a) vulnérabilité de logiciels

Introduction :

Les vulnérabilités logicielles sont des failles dans les applications ou systèmes qui permettent aux cyber attaquants de prendre le contrôle des ressources, d'exfiltrer des données ou de perturber les services.
Ces vulnérabilités, sont souvent des erreurs dans la conception ou le codage, menacent la sécurité des entreprises et des utilisateurs.
Pour sensibiliser à l'importance de sécuriser les logiciels, examinons certains types d'attaques moins connus, les méthodes employées par les attaquants, et les meilleures pratiques pour se protéger.



A. Types de vulnérabilités logicielles et exemples d'attaques

1. Désérialisation non sécurisée

La désérialisation non sécurisée survient lorsqu'un objet est transformé en données exploitables dans un programme sans vérification de sécurité, l'attaquant envoie un objet malveillant au serveur qui va lui permettre d'exécuter des commandes non autorisées.

En 2019, une vulnérabilité de désérialisation a été exploitée dans l'application WebLogic d'Oracle qui développe et déploie des applications Java d'entreprise. Les attaquants après cela pouvaient exécuter du code malveillant à distance.

Afin de s'en protéger, il est essentiel de vérifier l'intégrité des objets avant la désérialisation et d'éviter la désérialisation de données c'est-à- dire convertir un format sérialisé en un objet ou une structure de données utilisable par le programme provenant de sources non fiables. Limiter les classes de données dé-sérialisables , convertir un objet ou une structure de données en un format qui peut être facilement stocké et recourir à des formats de données sécurisés (comme JSON) aide également à réduire les risques.

2. Faille de type "Race Condition" (condition de course)

Une condition de course est lorsque deux processus tentent d'accéder simultanément aux mêmes ressources et modifient des données de manière imprévue. l'attaquant va profiter de cette situation pour obtenir des accès non autorisés ou manipuler des données sensibles.

En 2020, une vulnérabilité de type "race condition" a été découverte dans le système de fichiers de Linux, plus précisément dans le gestionnaire de fichiers *"fs/exec.c"* utilisé pour le montage et la gestion des fichiers exécutables. Cette vulnérabilité permettait à un attaquant local de contourner les contrôles de sécurité du noyau et d'obtenir des privilèges élevés, comme ceux de l'administrateur (*root*) ce qui a permis à des attaquants d'augmenter leurs privilèges et d'accéder à des fichiers système sensibles.

Afin de s'en protéger il est important d'assurer une synchronisation stricte des processus concurrents et de mettre en place des contrôles d'accès corrects.
utiliser verrous (locks) sur des ressources partagées aide également à réduire les risques de conditions de course.

3. Exposition de données sensibles (Sensitive Data Exposure)

L'exposition de données sensibles est lorsque des informations confidentielles (comme des mots de passe ou des numéros de carte bancaire) ne sont pas protégées de manière bien adaptée.
en 2021, des données de vaccination de plusieurs millions de personnes ont été accidentellement exposées en ligne en raison d'une mauvaise configuration de la sécurité.

Afin de se protéger de l'exposition des données sensibles, il est essentiel de chiffrer toutes les données en transit et au repos. La gestion des permissions et l'authentification des accès aux données sensibles aident également à éviter que des informations soient involontairement exposées.

B. Les méthodes employées par les attaquants pour exploiter ces failles

1. Utilisation d'outils de balayage et de reconnaissance

Les attaquants utilisent des outils comme **Nmap (network mapper)** pour balayer les ports ouverts et identifier les services actifs sur les systèmes cibles. Ces informations leur permettent de repérer des points faibles, comme des services mal configurés ou des versions obsolètes de logiciels.

La protection passe par la restriction de l'accès aux services non nécessaires, la fermeture des ports inutilisés et l'utilisation de pare-feu et de solutions de détection d'intrusion pour identifier les tentatives de balayage.

2. Conception de scripts malveillants et d'outils de test de pénétration détournés

Les attaquants peuvent concevoir des scripts ou détourner des outils comme Metasploit pour automatiser leurs attaques et exploiter les vulnérabilités connues. Ces outils leur permettent de tester les failles de sécurité et de contourner les mécanismes de protection.

Protection : Les équipes de sécurité peuvent également utiliser ces outils pour tester leurs propres systèmes et corriger les vulnérabilités détectées. En appliquant régulièrement les correctifs de sécurité et en limitant les droits d'accès, on peut réduire l'impact potentiel des attaques.

3. Techniques d'ingénierie sociale et de phishing

Les attaquants manipulent les utilisateurs pour obtenir leurs identifiants ou les inciter à cliquer sur des liens malveillants. Le phishing est souvent utilisé pour voler des informations de connexion ou installer des logiciels espions sur les ordinateurs des victimes.

La formation des utilisateurs est cruciale pour les sensibiliser aux techniques de phishing. Les entreprises peuvent également utiliser des filtres anti-phishing et des solutions d'authentification multi-facteurs pour minimiser les risques d'attaques réussies.

C. Conséquences d'une mauvaise gestion des vulnérabilités et mesures de protection avancées

1. Perte de données sensibles et atteinte à la confidentialité

Des attaques réussies qui exploitent des données peuvent entraîner des pertes de grande envergure, comme lors de la violation de données de l'application MyFitnessPal en 2018, où les informations de millions de comptes ont été exposées.

Protection : Les entreprises doivent chiffrer les données sensibles, restreindre les accès et appliquer des politiques de gestion des droits pour limiter les risques d'exposition de données sensibles.

2. Atteinte à la réputation de l'entreprise

Exemple : Une entreprise qui subit une attaque perd la confiance de ses clients, ce qui peut engendrer une perte de clientèle et des coûts élevés pour restaurer son image. Le cas de l'attaque de la chaîne Marriott, qui a compromis les données de millions de clients en 2018, montre l'impact durable sur la réputation.
Protection : Pour limiter les risques réputationnels, les entreprises doivent mettre en place une gestion de crise, être transparentes avec les clients en cas d'incident, et effectuer des audits réguliers pour renforcer leur sécurité.

3. Pertes financières et impacts juridiques

Exemple : Les cyberattaques peuvent entraîner des pertes financières directes (comme le vol d'argent ou le paiement de rançons) et des amendes réglementaires, comme celles imposées par le RGPD en Europe pour les violations de données.

Protection : Les entreprises doivent investir dans des solutions de sécurité comme les systèmes de détection d'intrusion, les antivirus et les sauvegardes régulières des données pour réduire les impacts financiers et juridiques des attaques.

Conclusion :

Les vulnérabilités logicielles constituent un risque majeur pour la sécurité des systèmes d'information. À travers divers types d'attaques, les cybercriminels exploitent ces failles pour voler des données, interrompre les services et nuire à la réputation des entreprises. Il est donc essentiel d'adopter des mesures préventives, telles que la validation des entrées utilisateur, l'application de correctifs de sécurité, et le suivi des bonnes pratiques de développement. En sensibilisant les utilisateurs et les entreprises aux menaces liées aux vulnérabilités logicielles, on renforce la sécurité des systèmes, protège les données sensibles et diminue l'impact des cyberattaques.

B) Vulnérabilité liés aux contrôle d'accès

introduction :
Le contrôle d’accès est une mesure de sécurité cruciale pour restreindre l’accès aux ressources et aux données sensibles d’un système. Il se divise en deux grandes catégories : le contrôle d’accès physique et le contrôle d’accès logique. Le contrôle d’accès physique utilise des dispositifs comme les badges RFID, les systèmes de verrouillage électronique et la biométrie pour gérer l’entrée dans des espaces physiques (bâtiments, salles de serveurs, etc.). Quant au contrôle d’accès logique, il concerne l’accès aux systèmes informatiques et aux informations via des méthodes comme l’authentification à deux facteurs (2FA) et les autorisations basées sur les rôles (RBAC). Cependant, malgré leur importance, les systèmes de contrôle d’accès présentent des vulnérabilités que les attaquants peuvent exploiter pour contourner ces protections et accéder illégalement aux informations. Cette rédaction explore les vulnérabilités du contrôle d’accès, les techniques d’attaque, ainsi que les moyens de protection pour sensibiliser à l’importance de renforcer ces dispositifs.

A) Contrôle d'accès physique

Le contrôle d'accès physique permet de protéger les espaces physiques contre l'accès non autorisé. Cela peut inclure des bâtiments, des salles de serveurs ou des zones sensibles nécessitant une protection accrue. Les méthodes de contrôle incluent :

1. Badges d'accès, cartes magnétiques et RFID

Ces dispositifs permettent aux utilisateurs autorisés de s'identifier et d'accéder à des zones spécifiques en scannant leur badge ou carte.

2. Systèmes de verrouillage électronique

Ces systèmes comprennent des codes PIN, des cartes d'accès et des dispositifs biométriques comme des empreintes digitales ou des reconnaissances faciales.

3. Contrôle d'accès biométrique

L'utilisation de technologies biométriques telles que les empreintes digitales, la reconnaissance faciale ou de l'iris permet une identification unique et sécurisée des utilisateurs. Ces systèmes sont souvent utilisés pour des accès très sensibles, comme les salles de données ou les bureaux de haute sécurité.

Objectif du contrôle d'accès physique :
Limiter l'entrée dans des zones sensibles pour éviter toute intrusion ou sabotage physique.

B) Contrôle d'accès logique :

Authentification à deux facteurs (2FA) :
L'utilisateur reçoit un code par SMS ou via une application d'authentification pour confirmer son identité.

Contrôle d'accès basé sur les rôles (RBAC) :
Seuls les membres d'une équipe spécifique, comme l'équipe juridique, peuvent accéder à des documents sensibles.

Accès conditionnel :
L'accès à distance est autorisé uniquement si l'utilisateur se connecte depuis un réseau sécurisé, comme un VPN. Les connexions publiques se voient refuser l'accès.

Audit des accès :
Enregistrement de toutes les tentatives de connexion, qu'elles soient réussies ou échouées.

Le contrôle d'accès joue un rôle crucial dans la protection des données en garantissant que seules les personnes autorisées peuvent accéder, modifier ou supprimer des informations sensibles, réduisant ainsi le risque de violations de la sécurité.

C) Les attaques en contrôle d'accès logique :

L'attaque par force brute:

l' hacker va tester systématiquement toutes les combinaisons possibles de caractères pour casser un mot de passe ou une clé de cryptage. Elle ne nécessite pas de connaissances spécifiques sur la cible, mais repose sur du temps et de la puissance de calcul. Plus le mot de passe est complexe et long, plus l'attaque sera difficile à réussir. Il existe trois attaques possibles.

L'attaque par force brute simple :

consiste à tester toutes les combinaisons possibles de lettres et de symboles, en commençant par les plus courtes, comme "a", "b", puis des combinaisons plus complexes comme "aa" ou "ab". Cette méthode devient inefficace lorsque les mots de passe sont longs ou complexes.
En revanche,

la force brute avec dictionnaire :
utilise une liste de mots de passe courants ou de termes trouvés dans des dictionnaires de langue pour tenter de deviner rapidement les identifiants souvent utilisés, tels que "password" ou "123456". Cette méthode est plus rapide mais limitée aux mots de passe prévisibles
Source:https://www.proofpoint.com/fr/threat-reference/brute-force-attack

Liste de mots de passe couramment utilisés :
Tableau ci-dessus

1. admin	**6. 123**	**11. demo**	**16. 01031974**
2. 123456	**7. 12345**	**12. root**	**17. Admin@123**
3. 12345678	**8. admin123**	**13. 123123**	**18. 111111**
4. 1234	**9. 123456789**	**14. admin@123**	**19. admin1234**
5. Password	**10. adminisp**	**15. 123456aA@**	**20. admin1**

L'attaque hybride :

combine la force brute et les attaques par dictionnaire. Cette technique permet de contourner des mots de passe un peu plus sophistiqués que les mots de passe de base, en les modifiant légèrement, tout en restant dans des combinaisons fréquentes et faciles à deviner.
Exemples d'outils utilisés par les pirates pour forcer les mots de passe : Aircrack-ng ,John the Ripper, LOphtCrack, Hashcat, Dave Grohl, Ncrack (recherche a faire)

Pour se protéger contre ces types d'attaques, il est essentiel de renforcer la sécurité des mots de passe et des systèmes.

Comment se protéger de cela ?

Tout d'abord, il est recommandé d'utiliser des mots de passe longs et complexes, d'au moins 12 à 16 caractères, qui combinent majuscules, minuscules, chiffres et symboles.

Des phrases de passe avec des phrases longues et complexes :

Elle consiste à créer une phrase qui ait du sens, mais qui soit suffisamment longue et difficile à deviner, tout en incluant des majuscules, des chiffres et des symboles pour la rendre encore plus sécurisée.

Par exemple :

- "L'astreDuJourBrilleFortMalgréLaPluie!2024!"
- "MonChienEstToujoursPrêtÀMeSuivrePartout#4567!"
- "LeVoyageEnTrainVersLeSudEstUneAventureExtraordinaire2024@!"

Combinaison de mots aléatoires avec chiffres et symboles :
Sa consiste a mélanger des mots qui n'ont aucun lien entre eux mais de les rendre complexes par l'ajout de caractères spéciaux et de chiffres :

- "Montagne&Plage#2024@!"
- "CaféLune@18Spirale!"
- "RivièreVéloPommes7#2024!"

Mots de passe avec caractères spéciaux et chiffres :
Cette méthode consiste à rendre le mot de passe plus difficile à cracker en insérant des chiffres, des caractères spéciaux et une diversité de lettres en majuscules et minuscules. Voici quelques exemples :

- "R!v3rF0x_2024$"
- "Luna#Etoile1$Soleil!"
- "V!n0b3r5-Éch@ng3!2024"

Attaque de contrôle d'accès via des failles Bluetooth

L'attaque de contrôle d'accès via des failles Bluetooth exploite des faiblesses dans la sécurité du protocole Bluetooth, permettant aux attaquants de contourner les restrictions d'accès à l'appareil ciblé.
Exemples d'attaques courantes de failles Bluetooth pour compromettre le contrôle d'accès :

Blueborne : Cette attaque, découverte en 2017, permet à un attaquant de prendre le contrôle d'un appareil sans nécessiter de couplage (pairing) Bluetooth, simplement en étant à proximité. Blueborne exploite des failles dans les protocoles de communication Bluetooth pour infiltrer les appareils, leur permettant d'accéder aux informations personnelles de l'utilisateur et d'exécuter des commandes.

Bluesnarfing : Une attaque par laquelle un attaquant accède et vole des données d'un appareil Bluetooth vulnérable, souvent sans que l'utilisateur s'en rende compte. En exploitant les failles de sécurité dans le protocole Bluetooth, l'attaquant peut contourner le contrôle d'accès et obtenir des informations telles que les contacts, les messages, voire les fichiers sur certains appareils.

Spoofing de périphériques : Un attaquant peut usurper l'identité d'un appareil Bluetooth de confiance (comme une enceinte, une montre connectée ou une voiture) pour induire en erreur un autre appareil et se connecter à celui-ci. Cela permet de contourner le contrôle d'accès et d'obtenir un accès non autorisé.

Attaque de sniffing Bluetooth (Interception des communications) :
Le sniffing Bluetooth consiste à intercepter et à analyser les communications Bluetooth non sécurisées entre des appareils. Un attaquant peut capter les données envoyées entre des appareils pairés pour voler des informations sensibles. Bien que les connexions Bluetooth modernes utilisent des protocoles de chiffrement, de nombreuses anciennes versions du

Bluetooth ou des appareils mal configurés peuvent encore transmettre des données non chiffrées.

pour cette attaque l'attaquant va utiliser **Wireshark** qui est un logiciel d'analyse de paquets réseau et d'un **Adaptateur Bluetooth USB**.

Pour se protéger, il est conseillé de garder le Bluetooth désactivé lorsqu'il n'est pas nécessaire, d'éviter les connexions Bluetooth avec des appareils inconnus, et de maintenir les appareils à jour avec les derniers correctifs de sécurité.

conclusion :

Pour conclure, notre catalogue sur les vulnérabilités met en évidence les dangers omniprésents de l'informatique. Il nous permet de mieux comprendre les risques liés aux failles de sécurité, tels que le phishing, les vulnérabilités des API et des logiciels, ainsi que l'importance cruciale des contrôles d'accès. Cette prise de conscience nous incite à renforcer nos pratiques de cybersécurité, à anticiper les menaces et à mettre en place des stratégies de protection efficaces pour préserver nos systèmes face à un environnement numérique de plus en plus complexe et menaçant.

Il est donc essentiel de ne pas sous-estimer ces risques et de prendre des mesures préventives dès aujourd'hui pour assurer la sécurité des données et des infrastructures à long terme.